5.2.2 The Bearer authentication scheme

Passing the token in a `X-CSRF-Token` header is less than ideal for tokens that have nothing to do with CSRF. You could just rename the header, and that would be perfectly acceptable. However, a standard way to pass non-cookie-based tokens to an API exists in the form of the *Bearer token* scheme for HTTP authentication defined by RFC 6750 (https://tools.ietf.org/html/rfc6750). While originally designed for OAuth 2 usage (chapter 7), the scheme has been widely adopted as a general mechanism for API token-based authentication.

> **DEFINITION** A ***bearer token*** is a token that can be used at an API simply by including it in the request. Any client that has a valid token is authorized to use that token and does not need to supply any further proof of authentication. A bearer token can be given to a third party to grant them access without revealing user credentials but can also be used easily by attackers if stolen.

To send a token to an API using the Bearer scheme, you simply include it in an Authorization header, much like you did with the encoded username and password for HTTP Basic authentication. The token is included without additional encoding:[3]

```
Authorization: Bearer QDAmQ9TStkDCpVK5A9kFowtYn2k
```